1. SPRINT PLANNING DOCUMENTADO — SPRINT 1

Nota 2 — Sprint Review 1: Primer Incremento Funcional (20%)

Proyecto: Sistema de Gestión y Compra de Libros en Línea
Frontend (Vercel): https://sistema-de-gestion-three.vercel.app/
Backend Swagger (Render): https://libreria-backend-yhdj.onrender.com/docs
Repositorio GitHub: github.com/josedavidmarin/Sistema-de-Gesti-n-y-Compra-de-Libros-en-L-nea

Equipo de Desarrollo:
• Jose David Marín Giraldo (josedavid.marin@utp.edu.co)
• Edwin Osorio Cartagena
• Maicol Londoño Hernández
Base de Datos Cloud: PostgreSQL (Supabase) + SQLite local

1. Sprint Goal (Objetivo del Sprint)

Sprint Goal: *"Construir y desplegar en producción el núcleo operativo de seguridad, gestión de identidad y control de acceso basado en roles (RBAC) del sistema mediante autenticación JWT y cifrado bcrypt, garantizando el autoservicio de clientes, la administración auditada por el usuario Root y el bloqueo atómico de compras o reservas para cuentas administrativas (RF-031) en una arquitectura cliente-servidor funcional, probada y demostrable de extremo a extremo."*

2. Historias Comprometidas en el Sprint 1 (21 Story Points)

De acuerdo con la priorización MoSCoW de la Nota 1 y estimación Fibonacci (Planning Poker), el equipo comprometió 7 Historias de Usuario **Must Have** (7 SP por integrante):

ID	Título de la Historia de Usuario	Prioridad (MoSCoW)	Estimación	Responsable	Requisitos
HU-01	Registro de nuevos clientes con DNI único y contraseña cifrada	**Must Have**	**5 SP**	Edwin Osorio	RF-027, RF-029
HU-04	Inicio de sesión (Login) y emisión de Bearer Token JWT con roles tipados	**Must Have**	**3 SP**	Jose David Marín	RF-026, RF-028
HU-05	Cierre de sesión (Logout) e invalidación de credenciales en cliente y servidor	**Must Have**	**1 SP**	Jose David Marín	RF-026
HU-06	Cambio seguro de contraseña con validación obligatoria de clave previa	**Must Have**	**2 SP**	Edwin Osorio	RF-028
HU-07	Consulta y actualización de perfil, correspondencia y monedero virtual	**Must Have**	**3 SP**	Jose David Marín	RF-021, RF-028, RF-037
HU-02	Creación exclusiva de Administradores por Superadmin Root con auditoría	**Must Have**	**5 SP**	Maicol Londoño	RF-030
HU-03	Restricción estricta de compras y reservas para Administradores y Root	**Must Have**	**2 SP**	Maicol Londoño	RF-031

3. Justificación de Cada Historia Comprometida

3.1 Capacidad del Equipo (~3 Semanas)

El equipo de 3 integrantes dispuso de 3 semanas (~10 a 12 horas/semana por persona = **90 a 108 horas-hombre totales**). Considerando ~4.5 horas por Story Point (desarrollo fullstack, documentación en inglés, pruebas automatizadas, notebook y despliegue en la nube), comprometer **21 SP (7 SP por integrante)** garantizó una carga sostenible sin deuda técnica.

3.2 Dependencias Técnicas y Justificación Individual por Historia

- **HU-04 (Login JWT — 3 SP):** Cimiento técnico del sprint. Provee la firma HS256 y el inyector get_current_user del cual dependen directamente HU-02, HU-03, HU-05, HU-06 y HU-07.
- **HU-01 (Registro de Clientes — 5 SP):** Punto de entrada para compradores (rol CLIENTE). Implementa el modelo relacional, unicidad de DNI/email y cifrado bcrypt, habilitando cuentas reales para probar login y perfil.
- **HU-05 (Logout — 1 SP):** Cierra el ciclo de vida de la sesión iniciada en HU-04 limpiando credenciales en cliente (AuthContext) y confirmando en POST /auth/logout.
- **HU-07 (Perfil y Monedero — 3 SP):** Depende de HU-04 (GET/PUT /auth/me). Permite gestionar teléfono y dirección de envío (RF-021) y consultar el saldo del monedero virtual (RF-037), requisito previo para futuras compras.
- **HU-06 (Cambio de Contraseña — 2 SP):** Depende de HU-04 y HU-07. Cumple RF-028 verificando criptográficamente la contraseña actual e impidiendo reutilizar la misma clave antes de re-hashear con bcrypt.
- **HU-02 (Creación de Administradores por Root — 5 SP):** Depende de HU-04 y del guardián require_roles(['ROOT']). Cumple RF-030 (prohibido el autorregistro de administradores; solo Root los crea y audita). Es prerrequisito para que en el Sprint 2 los administradores gestionen libros.
- **HU-03 (Restricción de Compras RF-031 — 2 SP):** Depende de HU-01, HU-02 y HU-04. Implementa el middleware verify_client_only que bloquea con HTTP 403 Forbidden cualquier compra o reserva intentada por ADMINISTRADOR o ROOT.

3.3 Prioridad Frente al Resto del Backlog

Construir catálogo, inventario o carrito sin tener autenticados los 3 roles (ROOT, ADMINISTRADOR, CLIENTE) y sus permisos RBAC habría obligado a exponer endpoints sin seguridad o con usuarios ficticios. Por ello, el módulo de Identidad y Seguridad tuvo prioridad máxima.

4. Historias que Quedaron Fuera del Sprint 1 y Por Qué

- **Catálogo e Inventario por Ejemplar Físico (HU-08, HU-09, HU-10, HU-10b, HU-14 — 27 SP):** Requieren que el rol ADMINISTRADOR (HU-02) esté creado y auditado. Además, sumar 27 SP habría duplicado la capacidad del equipo. Pasan al **Sprint 2 (Nota 3)**.
- **Reservas 24h, Carrito y Pagos (HU-11, HU-12, HU-13 — 16 SP):** Dependen de que existan libros y ejemplares físicos en base de datos (Sprint 2). Pasan al **Sprint 3**.
- **Logística, Envíos y Devoluciones QR (HU-14, HU-15, HU-20, HU-21 — 14 SP):** Historias *Should Have / Could Have* que requieren compras previas. Pasan al **Sprint 4**.

5. Criterios de Aceptación por Historia Comprometida

- **HU-01 (Registro):** CA-01: DNI y email únicos + clave >= 6 caracteres en POST /auth/register retorna 201 Created con rol CLIENTE y hash bcrypt. CA-02: DNI o email repetido retorna 400 Bad Request. CA-03: Validación de confirmación de clave y Ley 1581.
- **HU-04 (Login JWT):** CA-01: Credenciales válidas en POST /auth/login retornan 200 OK y JWT (HS256, 24h, claims: sub, rol, user_id, nombre). CA-02: Clave o email erróneo retorna 401 Unauthorized. CA-03: Redirección automática según rol.
- **HU-05 (Logout):** CA-01: Al cerrar sesión, invoca POST /auth/logout (200 OK), limpia localStorage, pasa a VISITANTE y bloquea rutas privadas.
- **HU-06 (Cambio de Clave):** CA-01: Clave actual incorrecta en PUT /auth/change-password retorna 400 Bad Request. CA-02: Nueva clave igual a la actual retorna 400 Bad Request. CA-03: Clave válida re-hashea con bcrypt y retorna 200 OK.
- **HU-07 (Perfil y Monedero):** CA-01: GET /auth/me retorna perfil y saldo ($150.000 COP). CA-02: PUT /auth/me actualiza teléfono y dirección (200 OK). CA-03: Impide modificar DNI, email, rol o saldo.
- **HU-02 (Crear Admin por Root):** CA-01: Rol ROOT en POST /admin/create-admin crea ADMINISTRADOR auditado (201 Created). CA-02: CLIENTE o ADMINISTRADOR intentando acceder recibe 403 Forbidden. CA-03: Root puede activar/suspender cuentas.
- **HU-03 (Restricción RF-031):** CA-01/CA-02: ADMINISTRADOR o ROOT en POST /compras/validar-permiso-compra-reserva recibe 403 Forbidden. CA-03: CLIENTE recibe 200 OK.

6. Definition of Done (DoD) del Equipo

Una historia se considera 'DONE' (Terminada) únicamente cuando cumple estos 6 criterios:

1. **Integrada:** Backend (FastAPI + SQLAlchemy) + Base de Datos (PostgreSQL/SQLite) + Frontend (React/TS) comunicándose extremo a extremo.
2. **Documentada en inglés:** Docstrings PEP-257, esquemas Pydantic y comentarios JSDoc en inglés técnico.
3. **Probada automáticamente:** Casos de éxito y error (400, 401, 403) aprobados al 100% en backend/test_sprint1_api.py.
4. **Reproducible en Notebook:** Verificada con assert en notebooks/demo_sprint1.ipynb.
5. **Trazable en Git y Tablero:** Commits con prefijo HU-XX:, vinculada a su Issue en GitHub Projects y desplegada en Vercel + Render.
6. **Demostrable en vivo:** Operativa en tiempo real para la sustentación ante el Product Owner.

UNIVERSIDAD TECNOLÓGICA DE PEREIRA

Facultad de Ingenierías • Programa de Ingeniería de Sistemas y Computación • IS873 Laboratorio de Software (2026-2)

5. NOTAS DE SUSTENTACIÓN (DOCUMENTO BREVE)

Nota 2 — Sprint Review 1: Primer Incremento Funcional (20%)

Proyecto: Sistema de Gestión y Compra de Libros en Línea
Frontend (Vercel): https://sistema-de-gestion-three.vercel.app/
Backend Swagger (Render): https://libreria-backend-yhdj.onrender.com/docs
Repositorio GitHub: github.com/josedavidmarin/Sistema-de-Gesti-n-y-Compra-de-Libros-en-L-nea

Equipo de Desarrollo:
• Jose David Marín Giraldo (josedavid.marin@utp.edu.co)
• Edwin Osorio Cartagena
• Maicol Londoño Hernández
Base de Datos Cloud: PostgreSQL (Supabase) + SQLite local

1. ¿Qué se comprometió al inicio del Sprint 1?

Al inicio del Sprint 1, el equipo comprometió **21 Story Points** distribuidos en **7 Historias de Usuario Must Have** (7 SP por integrante), con el objetivo de entregar el módulo de identidad, autenticación JWT y control de acceso basado en roles (RBAC) 100% funcional y desplegado:

- **HU-01 (5 SP — Edwin Osorio):** Registro de nuevos clientes con validación de DNI/email únicos y hashing bcrypt (RF-027, RF-029).
- **HU-04 (3 SP — Jose David Marín):** Inicio de sesión con emisión de Bearer Token JWT firmado (HS256, 24h) y claims de rol (RF-026, RF-028).
- **HU-05 (1 SP — Jose David Marín):** Cierre de sesión (Logout) e invalidación del estado de sesión en cliente y servidor (RF-026).
- **HU-06 (2 SP — Edwin Osorio):** Cambio seguro de contraseña validando clave actual e impidiendo reutilización (RF-028).
- **HU-07 (3 SP — Jose David Marín):** Consulta y actualización de perfil, dirección de envío y monedero virtual (RF-021, RF-028, RF-037).
- **HU-02 (5 SP — Maicol Londoño):** Creación exclusiva de Administradores por el Superadmin Root con auditoría (RF-030).
- **HU-03 (2 SP — Maicol Londoño):** Restricción estricta (HTTP 403 Forbidden) que prohíbe a Administradores y Root realizar compras o reservas (RF-031).

2. Historias no completadas y por qué (Respuesta Honesta)

- **Historias comprometidas pendientes: 0 historias sin completar (7 de 7 historias comprometidas fueron terminadas = 21 de 21 Story Points al 100%).**
- **Reflexión honesta sobre el alcance:** En la primera semana consideramos incluir también un CRUD preliminar de libros dentro de este mismo sprint para que la prueba de compra mostrara títulos desde la base de datos. Sin embargo, al enfrentar el trabajo real de desplegar en la nube (Vercel + Render + Supabase PostgreSQL), escribir la suite de pruebas automatizadas con casos borde y contenedorizar con Docker, reconocimos honestamente que abarcar el CRUD de libros habría dejado ambos módulos incompletos. Decidimos enfocar toda la capacidad en cerrar al 100% las 7 historias comprometidas de seguridad y RBAC sin deuda técnica.

3. Decisiones Técnicas no Previstas en el Plan Original

Durante la ejecución del Sprint 1 tomamos **5 decisiones técnicas emergentes** que no estaban en el documento original de la Nota 1:

1. **Migración a Base de Datos Cloud en PostgreSQL (Supabase) con Fallback SQLite:** Inicialmente usamos solo SQLite local. Al desplegar en Render detectamos que el disco local del contenedor es efímero (se reinicia en cada deploy). Configuramos PostgreSQL en Supabase mediante Session Pooler IPv4 (DATABASE_URL) para producción y mantuvimos

SQLite automático para pruebas locales y el Notebook.

2. **Estandarización de Python 3.10.14 y UTF-8 en Render:** Render intentó ejecutar por defecto Python 3.14, rompiendo la compilación de greenlet/SQLAlchemy, sumado a un archivo requirements.txt en UTF-16LE. Se recodificó a UTF-8 agregando psycopg2-binary y se fijó .python-version en 3.10.14.
3. **Tipado Estático de Entorno en Vite (vite-env.d.ts) y vercel.json:** En Vercel, el acceso dinámico a import.meta.env impedía que Vite reemplazara estáticamente la URL del backend en el build de producción. Se creó vite-env.d.ts y las reglas SPA en vercel.json.
4. **Simulador Interactivo en Vivo para la Regla RF-031 (HU-03):** Como el carrito completo es del Sprint 3, creamos un módulo interactivo en ProfilePage.tsx conectado a POST /api/v1/compras/validar-permiso-compra-reserva para demostrar en vivo el bloqueo 403 Forbidden a Administradores/Root frente al 200 OK de Clientes.
5. **Semilla Idempotente (init_db.py) y Botones de Autorelleno en Login:** Se agregaron botones de carga rápida en LoginPage.tsx para alternar en un clic entre Root, Administrador y Cliente durante los minutos de la sustentación en vivo.

4. Distribución del Trabajo por Integrante y Cuellos de Botella

Integrante	Historias	SP	Responsabilidades y Entregables Técnicos Ejecutados
Jose David Marín Giraldo	**HU-04, HU-05, HU-07**	**7 SP**	Motor JWT (security.py), dependencias RBAC (deps.py), endpoints /login, /logout y /me, AuthContext.tsx, despliegue Vercel/Render/Supabase y demo_sprint1.ipynb.
Edwin Osorio Cartagena	**HU-01, HU-06**	**7 SP**	Registro de clientes con DNI/email único (RegisterPage.tsx), cambio seguro de contraseña (ProfilePage.tsx) y suite de pruebas automatizadas (test_sprint1_api.py).
Maicol Londoño Hernández	**HU-02, HU-03**	**7 SP**	Gestión exclusiva de Administradores por Root (admin.py, AdminPage.tsx), restricción de compras RF-031 (compras.py) y Dockerización (Dockerfile, docker-compose.yml).

Cuellos de Botella y Solución Aplicada:

- **Dependencia bloqueante en HU-04 (Middleware JWT):** Al inicio del sprint, las historias HU-02, HU-03 y HU-06 dependían de que el token JWT y get_current_user estuvieran listos. *Solución:* Priorizamos construir primero security.py y publicar los esquemas en Swagger (/docs) para destrabar el trabajo en paralelo.
- **Integración Cloud y CORS entre Vercel, Render y Supabase:** Surgieron bloqueos iniciales de CORS y formato de cadena de conexión (postgres:// vs postgresql://). *Solución:* Normalización automática de la URL en session.py y configuración explícita de orígenes permitidos.

5. ¿Qué pasa al Backlog del Siguiente Sprint (Nota 3 — Sprint 2)?

Con la seguridad y los roles terminados, pasan al **Sprint 2 (Nota 3)** las historias del **Módulo de Catálogo, Gestión de Libros e Inventario por Ejemplar Físico (~25 Story Points)**:

- **[HU-08] Consulta y búsqueda avanzada de libros en el catálogo (5 SP — Must Have):** Búsqueda y filtrado público por título, autor, ISBN, categoría y precio (RF-001, RF-005).
- **[HU-09 / HU-10] Gestión CRUD de libros por Administrador (5 SP — Must Have):** Alta, edición bibliográfica/precio y baja de libros protegida con el rol ADMINISTRADOR (RF-001, RF-003, RF-004).
- **[HU-10b] Control de inventario por ejemplar físico (5 SP — Must Have):** Gestión de copias individuales (código único, estado nuevo/usado y stock disponible) (RF-002, RF-005).
- **[HU-14] Vista administrativa de existencias y alertas de agotados (5 SP — Must Have):** Panel de control de stock para personal de tienda (RF-006).
- **[HU-11] Reserva temporal de ejemplares por 24 horas (5 SP — Must Have):** Bloqueo temporal de inventario para clientes autenticados aplicando la restricción RF-031 (RF-010).